

Security Report

summarize

MEDIUM RISK

CVSS v3.1 Base Score — Medium
4.2/10
CVSS:3.1/AV:L/AC:H/PR:L/UI:R/S:U/C:L/I:L/A:L

Skill File	SKILL6.md
Vulnerabilities	3
Evaluated by	Qwen/Qwen2.5-14B-Instruct
Date	2026-03-17 16:06:22

Executive Summary

The 'summarize' skill is designed to summarize URLs, files, and YouTube links using various models. It introduces medium to high risks due to potential data exfiltration, credential exposure, and indirect injection of malicious content. These vulnerabilities could allow attackers to leak sensitive data or gain unauthorized access to API keys.

Skill Purpose

The skill is designed to provide a convenient way to summarize various types of content. However, its reliance on external URLs and files, along with the need for API keys, makes it inherently risky if not properly secured.

CVSS v3.1 Base Metrics

Impact Score 3.4 / 10 Exploitability 0.8 / 10

Attack Vector	Local	Attack Complexity	High
Privileges Required	Low	User Interaction	Required
Scope	Unchanged	Confidentiality	Low
Integrity	Low	Availability	Low

Vector: CVSS:3.1/AV:L/AC:H/PR:L/UI:R/S:U/C:L/I:L/A:L

Vulnerability Findings

SKV-001 Summarization of URLs can lead to data exfiltration	HIGH
Category: DATA EXFILTRATION	
Affected Content	
<pre>bash summarize "https://example.com" --model google/gemini-3-flash-preview</pre>	
Why It Is Dangerous	
The skill allows summarizing URLs, which can potentially include sensitive information. If the URL points to a resource containing confidential data, summarizing it could inadvertently transmit that data outside the secure environment.	
Attack Scenario	
An attacker could provide a URL pointing to a document containing sensitive information. The agent would then fetch and summarize the content, potentially leaking sensitive data through the summarization service.	
Remediation	
Restrict the URLs that can be summarized to trusted sources or ensure that only public, non-sensitive URLs are processed.	

SKV-002 Hardcoded API keys in configuration

HIGH

Category: CREDENTIAL / SECRET EXPOSURE

Affected Content

```
- OpenAI: `OPENAI_API_KEY`  
- Anthropic: `ANTHROPIC_API_KEY`  
- xAI: `XAI_API_KEY`  
- Google: `GEMINI_API_KEY` (aliases: `GOOGLE_GENERATIVE_AI_API_KEY`, `GOOGLE_API_KEY`)
```

Why It Is Dangerous

The skill requires setting API keys in the environment, which could be hardcoded or stored insecurely. This exposes the risk of credential leakage if the environment variables are not properly managed.

Attack Scenario

An attacker gains access to the environment where the skill runs and retrieves the API keys, allowing them to make unauthorized API calls using the stolen credentials.

Remediation

Ensure that API keys are securely stored and never hardcoded in the skill or environment variables. Use secure vaults or secrets management solutions.

SKV-003 Processing of external content as input

MEDIUM

Category: INDIRECT / EMBEDDED INJECTION

Affected Content

```
bash  
summarize "/path/to/file.pdf" --model google/gemini-3-flash-preview
```

Why It Is Dangerous

The skill processes external files and URLs, which could contain malicious content. If an attacker can control the input, they might inject harmful content that gets processed by the summarization tool.

Attack Scenario

An attacker provides a crafted PDF or URL that contains malicious content. When the agent summarizes the input, it could execute unintended actions or leak sensitive data.

Remediation

Validate and sanitize all inputs before processing them with the summarization tool. Ensure that only trusted and sanitized inputs are allowed.

Dangerous Patterns Found

- summarize "https://example.com"
- OPENAI_API_KEY
- summarize "/path/to/file.pdf"

Safe Practices Observed

- --model google/gemini-3-flash-preview

Remediation Priority

1. First address the credential exposure by ensuring secure storage of API keys. Then restrict the URLs and files that can be processed to prevent data exfiltration and indirect injection attacks.